

Phishing Email Detection & Awareness Report

Task 2 — Analysis of real-world phishing samples, technical header forensics, risk classification, and organization-wide prevention guidelines.

PREPARED BY	Yousef Ahmed Fawzy
CIN ID	FIT/JUN26/CS9482
INTERNSHIP	Cyber Security Internship (Remote)
PERIOD	29 June 2026 – 29 July 2026
REPOSITORY	github.com/youseffawzyy27/ FUTURE_CS_02
REPORT DATE	July 2026

Table of Contents

1	Executive Summary
2	Methodology & Tools Used
3	Sample 1 — Fake Microsoft Account Alert
4	Sample 2 — Fake Chase Bank Alert
5	Sample 3 — Fake Coinbase Crypto Alert
6	Sample 4 — Bulk Marketing (Suspicious)
7	Comparative Risk Summary
8	Prevention & Awareness Guidelines
9	Conclusion & References

Scope note: All samples were sourced from public, safe-for-research phishing/spam archives ([rf-peixoto/phishing_pot](#) and the public [SpamAssassin](#) corpus). No live malicious links were ever clicked; all links and domains were inspected via static text analysis only.

Executive Summary

Phishing remains one of the most common and costly attack vectors faced by organizations today, succeeding primarily because users lack the awareness to recognize deceptive emails — not because of weak technical systems. This report analyzes four real, publicly archived email samples to demonstrate how phishing attacks are identified, classified, and prevented at both a technical and human level.

- Four real email samples were collected and analyzed end-to-end: sender headers, authentication results (SPF/DKIM), embedded links, and social-engineering content.
- Each sample was classified using a three-tier risk system: **Safe**, **Suspicious**, or **Phishing**.
- Three samples were confirmed **Phishing** (credential/financial theft attempts); one was classified **Suspicious** (unsolicited bulk marketing, non-malicious).
- A consolidated set of prevention guidelines and employee Do's/Don'ts is provided at the end of this report.

Methodology & Tools Used

Analysis Workflow

- **Collection** — sourced real phishing/spam samples from verified public research archives
- **Header Analysis** — examined From, Reply-To, Return-Path, and Authentication-Results (SPF/DKIM) for each sample
- **Domain & Link Inspection** — compared claimed brand domains against actual sending/link domains
- **Indicator Identification** — compiled spoofing, authentication, and social-engineering red flags
- **Risk Classification** — rated each sample Safe / Suspicious / Phishing based on cumulative evidence
- **Documentation** — compiled findings into this structured report
- **Prevention Guidelines** — produced actionable awareness guidance for end users and employees

Tools & Sources

- Public phishing sample archive: [rf-peixoto/phishing_pot](#) (GitHub)
- Public spam/ham research corpus: [SpamAssassin](#) public dataset
- Manual header inspection (raw .eml source review)
- Browser-based rendered-view inspection (safe, non-interactive)
- Text-based link/domain analysis (no live link clicks)

the link silently opens an email addressed to the attacker's own Gmail account, confirming the victim's address is active and opening the door to further social engineering.

Risk Classification: Phishing (High Risk). Multiple independent red flags — sender/reply/return domain mismatch, zero authentication, and deceptive action links — leave no plausible legitimate explanation.

Risk Classification: Phishing (High Risk). This is a strong example of why passing SPF/DKIM does *not* equal trustworthy — authentication only verifies the actual sending domain, which here is the attacker's own infrastructure.

Risk Classification: Phishing (High Risk). Multiple independent red flags — filter-evasion naming, unrelated sending domain, disguised redirect link, and urgency-based content — confirm malicious intent.

Comparative Risk Summary

Sample	Impersonated Brand	Key Red Flags	Risk Level
1. Account Alert	Microsoft	Fake domain, mismatched Reply-To/Return-Path, no SPF/DKIM	Phishing
2. Bank Alert	Chase	Display spoofing, SPF/DKIM pass for wrong domain, shortened malicious link	Phishing
3. Crypto Alert	Coinbase	Filter-evasion naming, SPF/DKIM pass for wrong domain, disguised redirect link	Phishing
4. Marketing Ad	None (self-branded)	Bulk-mail infrastructure, no impersonation, no credential theft	Suspicious

Key takeaway: Passing SPF and DKIM checks does **not** mean an email is safe. These checks only confirm an email truly came from the domain shown in its headers — and that domain can itself belong entirely to the attacker. Genuine safety requires checking whether that authenticated domain actually belongs to the organization the email claims to represent.

Prevention & Awareness Guidelines

General Prevention Tips for All Users

- Always check the **actual sender address**, not just the display name shown by your email client
- **Hover over links** before clicking to preview the real destination URL in your browser/email client status bar
- Treat urgency and fear-based language ("act now or lose access") as a red flag — verify independently through the organization's official website or app, never through the email itself
- Never reply to, or click "report/verify" links inside, a suspicious email — report it through your official IT/security channel instead
- Remember: an SPF/DKIM "pass" only proves the email came from the domain shown in its headers — it does **not** prove that domain is trustworthy
- Be cautious of generic greetings ("Dear Customer") in messages claiming to be from a service you use personally

Do's and Don'ts for Employees

✓ Do

- Verify the sender's actual domain before trusting an email
- Report suspicious emails to IT/Security immediately
- Hover over links to preview real destinations before clicking
- Enable multi-factor authentication on all accounts
- Confirm unusual financial/account requests via a separate, known channel (phone/official app)

✗ Don't

- Don't click links in unexpected "urgent" emails
- Don't reply to or engage with suspicious senders
- Don't enter credentials after clicking a link from an email
- Don't assume a passed security check means the sender is safe
- Don't forward suspicious emails to coworkers without flagging them to Security first

Conclusion & References

This analysis of four real email samples demonstrates that modern phishing attacks rarely rely on obvious technical flaws — instead, they exploit trust in familiar brands, urgency-driven decision-making, and the false confidence users place in passed authentication checks. Three of the four samples analyzed were confirmed high-risk phishing attempts targeting account credentials and financial assets, while the fourth demonstrated that not every irregular-looking email is malicious — context and cumulative evidence matter more than any single red flag.

The strongest defense against phishing combines technical awareness (understanding SPF/DKIM, header analysis, link inspection) with behavioral discipline (pausing before acting on urgency, verifying through independent channels, and reporting suspicious activity promptly).

References & Data Sources

- rf-peixoto/phishing_pot — Public phishing email archive (GitHub), used for Samples 1–3. Referenced for study purposes only; all analysis is original.
- SpamAssassin Public Corpus — Public spam/ham research dataset, used for Sample 4.
- Google Message Header Analyzer — toolbox.googleapps.com/apps/messageheader
- MxToolbox Email Header Analyzer — mxtoolbox.com/EmailHeaders.aspx

Note on ethics: All samples analyzed were sourced from public, research-oriented archives specifically intended for educational study. No live phishing links were clicked, no credentials were entered, and no content from reference repositories was copied or reused — all analysis, indicators, and conclusions in this report are original work.